

Feuille de route technique et créative de La Cabane du Lys

Plan d'amélioration du frontend du backend et de l'identité visuelle

Projet audité gabrielOtaku la cabane du lys platform

Document de travail destiné au pilotage de la version suivante de la plateforme.

Orientation recommandée

Faire évoluer le projet vers une plateforme média entrepreneuriale francophone, avec une identité immédiatement reconnaissable autour du feu, de la voix et de la fleur de lys.

Version du document 13 septembre 2026

Table des matières

- 1 Résumé des décisions
- 2 État actuel du projet
- 3 Direction artistique et expérience de marque
- 4 Architecture cible
- 5 Feuille de route par phases
- 6 Détail des améliorations frontend
- 7 Détail des améliorations backend
- 8 Sécurité et protection des données
- 9 Accessibilité et performance
- 10 Tests qualité et mise en production
- 11 Backlog priorisé
- 12 Organisation du travail
- 13 Critères de réussite
- 14 Annexes techniques

Mode d'emploi de la feuille de route

Les phases sont classées selon les dépendances du projet. Une phase peut commencer lorsque ses prérequis sont terminés et vérifiés. Les durées sont des ordres de grandeur pour un développeur principal qui travaille en parallèle de ses études et d'autres responsabilités.

- Mettre à jour la colonne Statut du backlog chaque semaine.
- Ne pas lancer une fonction visible en production sans ses états de chargement, d'erreur et de données vides.
- Terminer les corrections de sécurité critiques avant le back office et la boutique en production.
- Conserver une démonstration fonctionnelle à la fin de chaque phase.

1 Résumé des décisions

La base technique est assez solide pour poursuivre le projet sans refonte complète. La priorité consiste à unifier les systèmes déjà présents, corriger les failles fonctionnelles du backend et rendre l'identité visuelle plus cohérente. Le lecteur audio doit devenir la signature principale de la plateforme. Le curseur fleur de lys et les lucioles peuvent renforcer cette signature, à condition de rester accessibles et légers.

Décision	Pourquoi	Résultat attendu
Conserver la direction Obsidienne Bronze Ambre	La palette soutient déjà le positionnement premium et la chaleur de la conversation.	Une évolution cohérente sans perdre l'identité existante.
Unifier le lecteur audio	Deux implémentations coexistent et une simulation ne lit pas encore un véritable fichier audio.	Lecture continue, waveform réelle, transcription synchronisée et mini lecteur persistant.
Corriger l'authentification avant le back office	Le token reçu n'est pas conservé ni transmis et le rôle du JWT est ignoré par le filtre.	Accès membre et administrateur réellement séparés.

Décision	Pourquoi	Résultat attendu
Créer une vraie entité Drop	La date actuelle est recalculée à maintenant plus dix huit jours et le compte à rebours ne peut pas atteindre zéro.	Collections programmables depuis l'administration.
Réserver le stock avant paiement	Deux sessions Stripe peuvent être créées pour le dernier article avant le webhook.	Réduction du risque de survente pendant les drops limités.

Priorités immédiates

1. Sécuriser l'authentification, les rôles et le vrai flux de lien magique.
2. Corriger la logique des drops et la réservation de stock.
3. Unifier le moteur audio et rendre la lecture persistante.
4. Implémenter le curseur fleur de lys et les lucioles avec des options d'accessibilité.
5. Simplifier le Hero et remplacer progressivement les promesses génériques par des preuves réelles.
6. Modulariser les styles, stabiliser les données et préparer le back office.

2 État actuel du projet

Forces à conserver

- Monorepo séparant clairement le frontend Next et React du backend Spring Boot.
- TypeScript, TanStack Query, Zustand, Framer Motion, Lenis et React Three Fiber déjà intégrés côté interface.
- Spring Boot, PostgreSQL, Redis, Flyway, Stripe, JWT et WebAuthn déjà présents côté serveur.
- Architecture backend organisée autour des contrôleurs, services, dépôts, DTO et gestion globale des erreurs.
- Identité visuelle forte avec l'obsidienne, le bronze, l'ambre, le grain, les braises et une typographie éditoriale.
- Lecteur d'accueil capable d'analyser les fréquences réelles grâce à AudioContext et AnalyserNode.
- Prise en compte initiale de prefers reduced motion pour certains effets et le défilement fluide.
- Vérification de la signature des webhooks Stripe et limitation de débit via Redis.

Points de vigilance confirmés

Zone	Constat	Gravité	Action
Documentation	Le package frontend utilise Next 15.5.19 tandis que le README présente encore Next 14.	Moyenne	Aligner le README et les procédures.
Audio	EpisodePlayer simule le temps sans élément audio alors que le lecteur d'accueil utilise un vrai moteur.	Haute	Créer un moteur partagé.
Authentification	Le frontend reçoit un JWT mais ne le conserve pas et le client API ne l'envoie pas.	Critique	Choisir une session sécurisée et relier tout le flux.
Rôles	Le filtre JWT attribue toujours ROLE MEMBER même si le jeton contient un rôle.	Critique	Lire et valider la claim role.
Lien magique	Le backend renvoie directement un JWT au lieu d'envoyer un lien à usage unique.	Critique	Implémenter token court, expiration, courriel, callback et invalidation.
Boutique	La date du drop reste toujours à dix huit jours dans le futur.	Haute	Stocker les dates dans une entité Drop.

Zone	Constat	Gravité	Action
Stock	La décrémentation intervient au webhook sans réservation préalable.	Haute	Ajouter une réservation transactionnelle avec expiration.
Styles	Le fichier globals.css concentre environ 57 Ko de styles.	Moyenne	Découper les tokens, bases, animations et composants.
Rate limiting	X Forwarded For est accepté sans validation explicite du proxy de confiance.	Haute	Configurer les proxys approuvés et la résolution IP.

3 Direction artistique et expérience de marque

Positionnement recommandé

La Cabane du Lys devrait être présentée comme une maison éditoriale entrepreneuriale francophone. L'expérience peut conserver son atmosphère sombre et chaleureuse, tout en se rapprochant d'un magazine documentaire premium. Les effets doivent servir le récit, l'écoute et la lecture plutôt que se superposer sans fonction.

Système culturel

Origine	Rôle visuel	Applications recommandées	À éviter
Québec	Emblème et territoire	Fleur de lys, forêt boréale, brume, bois sombre, lumière hivernale, mention de Saint-Félicien.	Accumulation de symboles folkloriques ou de feuilles d'érable.
France	Éditorial et composition	Typographie, grandes citations, marges, chapitres, mise en page inspirée d'une maison d'édition.	Références littérales et décoratives sans lien avec le contenu.
Madagascar	Matière et chaleur	Terre rouge profonde, textures tissées abstraites, géométries discrètes, accents chaleureux.	Motifs culturels utilisés sans contexte ni recherche.

Langage d'animation

Limiter les animations à trois familles permet de rendre le site plus mémorable et plus facile à maintenir.

Famille	Usage	Comportement
Braise	Audio et lecture	Waveform, playhead, progression et quelques particules liées à l'intensité sonore.
Luciole	Clics et interactions	Petites lumières organiques de courte durée, avec trajectoires variées et disparition douce.
Gravure et dorure	Titres et contenu institutionnel	Tracé discret d'une ligne, révélation typographique et reflets bronze très limités.

Règles visuelles

- Utiliser un verre fumé autour de rgba 15 13 10 à 62 pour cent avec un flou d'environ 24 px et une saturation modérée.
- Limiter la bordure du lecteur à un filet bronze ou ambre très discret.
- Placer le feu dans la waveform, le playhead et la progression, pas autour de toute la carte.
- Réserver les effets 3D aux moments où ils améliorent la compréhension ou la présence de la marque.

- Éviter le collage de drapeaux et les symboles culturels répétés.
- Créer une échelle de mouvement commune pour les durées, accélérations, amplitudes et intensités lumineuses.

Le Hero et les preuves

Le Hero doit expliquer en quelques secondes ce que propose la plateforme, à qui elle s'adresse et quelle action accomplir. Les mentions comme 100 pour cent Transparence ou l'infini de leçons réelles pourront être remplacées dès que les vraies données seront disponibles.

- Nombre d'épisodes publiés.
- Nombre d'entrepreneurs rencontrés.
- Heures de conversation disponibles.
- Ancrage Saint Félicien vers la francophonie.

4 Architecture cible

Frontend

Le frontend doit séparer l'interface, les états applicatifs et les appels réseau. TanStack Query reste la source des données serveur. Zustand ne conserve que l'état local ou transversal qui n'appartient pas au serveur. Le lecteur audio persistant vit dans un fournisseur placé au niveau du layout principal.

Couche	Responsabilité	Exemples
Interface	Affichage et interaction accessible	Hero, cartes, lecteur, transcription, formulaires.
Composants de domaine	Règles propres aux épisodes et à la boutique	EpisodeCard, DropStatus, ProductCard.
État serveur	Chargement, cache et invalidation	TanStack Query et clés de requête cohérentes.
État client	Préférences locales et lecteur persistant	Zustand ou Context selon la portée.
Accès API	Requêtes typées, erreurs et session	Client HTTP unique et contrats DTO.

Moteur audio cible

Module	Responsabilité
AudioPlayerProvider	Conserver la piste, le temps, la lecture et le volume pendant la navigation.
AudioEngine	Gérer l'élément audio, les événements, l'analyse fréquentielle et le nettoyage des ressources.
WaveformVisualizer	Afficher une forme d'onde réelle et réduire son coût si le mouvement est limité.
TranscriptSync	Associer le temps courant aux segments de transcription et permettre la navigation par phrase.
MiniPlayer	Rester visible après le départ de la page et offrir les contrôles essentiels.

Backend

Le backend doit conserver la séparation contrôleurs, services, dépôts et DTO. Les nouvelles règles de domaine doivent être explicites dans les services et renforcées par des contraintes de base de données, des transactions et des tests d'intégration.

Domaine	Composants cibles	Règles principales
Identité	Session, MagicLinkToken, WebAuthnCredential, Role	Jetons à usage unique, expiration courte, révocation et autorisations serveur.
Épisodes	Episode, Guest, TranscriptSegment	Publication programmée, slugs uniques et médias validés.
Boutique	Drop, DropProduct, Product, StockReservation	Fenêtres d'ouverture, limites par client et réservation expirante.
Paiement	Checkout, Order, PaymentEvent	Idempotence, rapprochement Stripe et transitions d'état contrôlées.
Administration	AuditEvent et permissions	Actions sensibles journalisées et routes protégées par rôle.

5 Feuille de route par phases

La séquence ci dessous réduit le risque technique avant d'investir du temps dans le back office et les détails décoratifs. L'estimation complète se situe autour de douze à seize semaines à temps partiel. Elle doit être adaptée au calendrier scolaire et à la disponibilité réelle.

Phase 0 Stabilisation et référence

Durée indicative Deux à trois jours

Créer une base mesurable avant toute modification importante.

Travail à réaliser

- [] Mettre le README à jour avec Next 15.5.19 et les versions réellement utilisées.
- [] Créer une branche de travail V2 et protéger la branche principale.
- [] Documenter les commandes de démarrage frontend backend base de données Redis et Stripe CLI.
- [] Faire l'inventaire des routes, variables d'environnement, données de démonstration et fonctions incomplètes.
- [] Mesurer Lighthouse sur accueil épisode boutique connexion et mobile.
- [] Noter les tests actuellement verts et les scénarios manuels reproductibles.

Livrables

- README actualisé
- Rapport de référence
- Liste des variables d'environnement sans secrets
- Backlog initial

Critères de validation

- Un nouveau développeur peut démarrer le projet à partir du README.
- Chaque anomalie importante possède une tâche reproductible.
- Aucun secret réel n'est commité.

Phase 1 Sécurité de l'identité

Durée indicative Une à deux semaines

Rendre l'authentification exploitable en production et séparer réellement les permissions membre et administrateur.

La phase 0 doit être terminée afin de tester à partir d'une configuration connue.

Travail à réaliser

- [] Choisir la stratégie de session recommandée avec cookie HttpOnly Secure et SameSite ou documenter clairement une autre décision.
- [] Implémenter le vrai lien magique avec token aléatoire à usage unique, expiration, courriel, callback et invalidation.
- [] Relier le bouton de connexion du frontend au backend et gérer chargement succès expiration et renvoi.
- [] Lire la claim role dans JwtAuthenticationFilter et refuser les rôles invalides.
- [] Protéger les routes administratives avec les annotations et règles Spring Security appropriées.
- [] Ajouter déconnexion révocation et traitement des sessions expirées.
- [] Tester WebAuthn, lien magique, session, rôle membre et rôle administrateur.

Livrables

- Flux de connexion complet
- Rôles fonctionnels
- Tests d'intégration d'authentification
- Documentation de session

Critères de validation

- Un membre ne peut pas appeler une route administrateur.
- Un lien utilisé ou expiré est refusé.
- Le navigateur ne rend pas le secret de session accessible au JavaScript si la stratégie cookie est retenue.
- Les tests couvrent les réponses 401 et 403.

Phase 2 Drops paiements et stock

Durée indicative Une à deux semaines

Corriger les règles de boutique avant toute promotion d'un drop limité.

La session utilisateur de la phase 1 doit être stable pour appliquer les limites par client.

Travail à réaliser

- [] Créer les entités Drop et DropProduct avec opensAt closesAt status slug heroImage et maxPerCustomer.
- [] Remplacer le calcul maintenant plus dix huit jours par les dates persistées.
- [] Créer StockReservation avec quantité expiration et état.
- [] Réserver le stock dans une transaction avant la création de la session Checkout.
- [] Libérer automatiquement les réservations expirées.
- [] Rendre le webhook Stripe idempotent en stockant l'identifiant de l'événement traité.
- [] Vérifier le prix et le produit côté serveur sans accepter les montants du client.
- [] Tester deux achats simultanés sur le dernier article.

Livrables

- Migrations Flyway
- API de drops

- Réservation de stock
- Tests de concurrence
- Webhooks idempotents

Critères de validation

- Le compte à rebours atteint réellement zéro.
- Deux clients ne peuvent pas acheter la même dernière unité.
- Un webhook reçu deux fois ne crée pas deux commandes.
- Une réservation abandonnée rend le stock disponible après expiration.

Phase 3 Lecteur audio unifié

Durée indicative Une à deux semaines

Faire du lecteur audio glass et feu la signature fonctionnelle du produit.

Travail à réaliser

- [] Créer AudioPlayerProvider et AudioEngine au niveau du layout principal.
- [] Remplacer le temps simulé de EpisodePlayer par les événements du véritable élément audio.
- [] Réutiliser le même moteur sur l'accueil la page épisode et le mini lecteur.
- [] Synchroniser la transcription avec des segments horodatés.
- [] Ajouter lecture pause seek volume vitesse et reprise après navigation.
- [] Piloter la waveform et les braises à partir de l'intensité sonore sans multiplier les animations.
- [] Prévoir les états média absent chargement bloqué erreur réseau et lecture refusée.
- [] Ajouter le support clavier et les libellés accessibles.

Livrables

- Moteur audio unique
- Mini lecteur persistant
- Transcription synchronisée
- Tests unitaires et interaction

Critères de validation

- La lecture continue pendant la navigation.
- Le temps affiché correspond au média réel.
- Le composant fonctionne au clavier et avec mouvement réduit.
- Une seule instance audio joue à la fois.

Phase 4 Identité interactive

Durée indicative Quatre à six jours

Implémenter le curseur fleur de lys et les lucioles sans dégrader l'utilisation du site.

Le langage d'animation doit être fixé pour éviter de refaire les effets après coup.

Travail à réaliser

- [] Réutiliser le symbole SVG LysDefs et supprimer le point blanc actuel.

- [] Dimensionner la fleur entre quatorze et dix huit pixels sur bureau.
- [] Conserver le halo avec une inertie légère et limiter les transformations sur les éléments magnétiques.
- [] Créer six à neuf lucioles par clic avec durée de quatre cents à huit cents millisecondes.
- [] Ajouter les modes lien bouton texte lecture pause et élément 3D.
- [] Désactiver le curseur personnalisé sur écrans tactiles et avec mouvement réduit.
- [] Nettoyer tous les éléments de particules après leur animation.

Livrables

- CustomCursor V2
- Composant FireflyBurst
- Variables de mouvement
- Tests desktop tactile et clavier

Critères de validation

- Aucun décalage visible lors du déplacement rapide.
- Les champs texte conservent une indication de sélection compréhensible.
- Les lucioles ne provoquent pas de fuite mémoire.
- Le curseur natif reste disponible lorsque les effets sont désactivés.

Phase 5 Accueil et système visuel

Durée indicative Une à deux semaines

Clarifier le positionnement entrepreneurial et appliquer le système culturel de façon cohérente.

Travail à réaliser

- [] Réécrire le Hero autour de la proposition de valeur, d'un appel principal et d'un appel secondaire.
- [] Remplacer progressivement les promesses génériques par des chiffres vérifiables.
- [] Créer les tokens de couleur typographie espace rayon ombre mouvement et couche.
- [] Appliquer les trois familles d'animation braise luciole gravure et dorure.
- [] Intégrer Québec France et Madagascar selon le système emblème éditorial matière.
- [] Réduire les couches d'effets qui n'aident pas la lecture.
- [] Décliner correctement l'accueil sur mobile tablette et grand écran.

Livrables

- Hero V2
- Tokens documentés
- Composants visuels harmonisés
- Guide de direction artistique

Critères de validation

- La première vue explique le contenu et l'action attendue.
- Chaque animation appartient à une famille définie.
- Les références culturelles restent subtiles et cohérentes.
- Le contraste respecte WCAG AA pour le texte courant.

Phase 6 Données et modularisation frontend

Durée indicative Une à deux semaines

Réduire la dette technique et rendre les données prévisibles avant l'administration.

Travail à réaliser

- ☐ Choisir l'API comme source de vérité et limiter les fallbacks src data aux fixtures de développement.
- ☐ Uniformiser les clés TanStack Query et les règles de stale time cache et invalidation.
- ☐ Créer des états Skeleton ErrorState EmptyState et RetryAction réutilisables.
- ☐ Découper globals.css en tokens base animations audio et styles de pages ou en modules CSS.
- ☐ Isoler les composants lourds et utiliser le chargement dynamique pour la 3D lorsque pertinent.
- ☐ Supprimer les dépendances et styles non utilisés après vérification.
- ☐ Aligner les types frontend avec les DTO du backend.

Livrables

- Client API unique
- États d'interface cohérents
- Styles modulaires
- Contrats de données stabilisés

Critères de validation

- Une donnée de production ne provient pas silencieusement d'un fichier local.
- Les erreurs API sont compréhensibles et récupérables.
- Le CSS est réparti selon une convention documentée.
- Les composants lourds ne bloquent pas l'affichage initial.

Phase 7 Back office

Durée indicative Deux à trois semaines

Permettre la gestion des contenus sans modifier le code source.

Les phases 1 2 et 6 doivent être terminées.

Travail à réaliser

- ☐ Créer une navigation administrateur protégée.
- ☐ Gérer épisodes invités transcriptions médias statut brouillon et publication.
- ☐ Gérer drops produits stock dates images et limites par client.
- ☐ Afficher les commandes et états de paiement sans exposer de données inutiles.
- ☐ Ajouter validation serveur messages d'erreur et confirmations avant actions sensibles.
- ☐ Journaliser les actions administratives importantes.

Livrables

- Tableau de bord administrateur
- Éditeur de contenu
- Gestion de boutique
- Journal d'audit

Critères de validation

- Toutes les routes exigent le rôle administrateur.
- Les formulaires empêchent les données invalides côté client et serveur.
- Une action sensible laisse une trace exploitable.
- Le contenu peut être publié sans redéploiement.

Phase 8 Qualité et lancement

Durée indicative Une à deux semaines

Préparer une première version publique stable et mesurable.

Toutes les fonctions incluses dans la version publique doivent être terminées ou retirées proprement.

Travail à réaliser

- [] Finaliser les tests unitaires intégration composant et parcours critiques.
- [] Créer une intégration continue avec lint compilation tests et contrôle des migrations.
- [] Configurer les environnements développement préproduction et production.
- [] Ajouter logs structurés suivi des erreurs métriques de latence et alertes essentielles.
- [] Exécuter les audits Lighthouse accessibilité dépendances et en têtes de sécurité.
- [] Vérifier sauvegardes restauration et procédure de retour arrière.
- [] Réaliser une répétition de lancement en préproduction.

Livrables

- Pipeline CI
- Environnement de préproduction
- Rapport de recette
- Procédure de déploiement et retour arrière

Critères de validation

- Les parcours connexion écoute recherche et achat passent en préproduction.
- Aucune vulnérabilité critique connue ne reste ouverte.
- Le déploiement est reproductible.
- Une restauration de sauvegarde a été testée.

6 Détail des améliorations frontend

Lecteur audio

- Conserver le verre fumé, la waveform et l'animation de flamme.
- Faire correspondre les particules à l'énergie sonore plutôt qu'à une boucle décorative indépendante.
- Limiter l'extrait à trois minutes uniquement lorsque la stratégie éditoriale le demande et afficher clairement la durée disponible.
- Permettre un seek précis avec souris, toucher et clavier.
- Sauvegarder la position de lecture localement si cela sert l'expérience, sans stocker de données sensibles.

- Associer la phrase active de la transcription à une marque verticale bronze.
- Précharger uniquement les métadonnées sur les pages listant plusieurs épisodes.

Curseur et lucioles

- Utiliser le SVG existant au lieu d'une image PNG afin de préserver la netteté et les changements de couleur.
- Conserver un mode texte ou le curseur natif sur les zones de sélection.
- Ne pas bloquer les clics avec le calque du curseur grâce à pointer events none.
- Réduire le nombre de particules sur les appareils moins puissants.
- Créer une variante Play où quelques lucioles convergent vers la waveform.
- Tester le site sans souris pour vérifier que l'effet ne remplace aucune information essentielle.

Accueil et navigation

- Conserver l'ordre Hero Manifeste Coffre Salle Cercle Réserve Diffusion s'il correspond toujours au parcours éditorial.
- Raccourcir les textes de la première vue et déplacer les explications détaillées plus bas.
- Mettre en avant un épisode ou extrait principal plutôt qu'un grand nombre d'appels concurrents.
- Ajouter un mini lecteur persistant mais non intrusif.
- Fournir un état actif clair dans la navigation et un focus clavier visible.
- Prévoir une recherche avec résultats groupés épisodes invités et sujets.

Recommandations supplémentaires

- Créer des métadonnées SEO et cartes de partage propres à chaque épisode et invité.
- Générer un flux RSS si les épisodes doivent être distribués comme podcast.
- Utiliser des images responsives avec dimensions connues afin de limiter les déplacements de mise en page.
- Ajouter une page système pour les couleurs, composants et états afin de vérifier la cohérence.
- Suivre quelques événements utiles comme lecture démarrée, quartiles d'écoute, fin d'extrait et conversion vers un épisode complet.
- Demander un consentement adapté avant toute mesure non essentielle et minimiser les données collectées.

7 Détail des améliorations backend

Authentification et autorisation

Le point bloquant n'est pas l'absence de briques de sécurité, mais leur connexion incomplète. Le flux doit être conçu comme une seule chaîne, depuis la demande de connexion jusqu'à l'autorisation de la route serveur.

1. Le client demande un lien magique avec une adresse normalisée.
2. Le serveur crée un secret aléatoire, conserve seulement sa preuve ou son hachage et fixe une expiration courte.

3. Le courriel contient un lien HTTPS à usage unique.
4. Le callback valide le token, l'invalidé et crée la session.
5. Le navigateur reçoit un cookie de session protégé.
6. Chaque route sensible vérifie l'identité et le rôle côté serveur.

WebAuthn peut rester une méthode complémentaire. Les erreurs doivent être explicites sans révéler si une adresse est inscrite, afin de limiter l'énumération des comptes.

Drops et stock

- Définir clairement les états Draft Scheduled Open Closed Archived.
- Calculer l'état à partir des dates ou l'enregistrer avec des transitions contrôlées, mais éviter deux sources contradictoires.
- Créer une contrainte empêchant les quantités négatives.
- Verrouiller la ligne de stock ou utiliser une mise à jour conditionnelle atomique lors de la réservation.
- Associer chaque réservation à un utilisateur ou à un identifiant de panier signé.
- Traiter checkout session completed et les événements d'échec ou expiration nécessaires.
- Rendre chaque traitement idempotent avec l'identifiant Stripe.

API et données

- Valider tous les DTO entrants et renvoyer des codes HTTP cohérents.
- Paginer les listes d'épisodes invités produits commandes et recherches.
- Définir une convention de tri filtres et paramètres de requête.
- Éviter d'exposer directement les entités JPA dans les réponses.
- Ajouter des index sur les recherches fréquentes et vérifier les plans de requête.
- Documenter l'API avec OpenAPI et fournir des exemples de réponses sans données sensibles.

Observabilité

- Utiliser des logs structurés avec identifiant de corrélation.
- Ne jamais écrire tokens, cookies, secrets Stripe ou données personnelles inutiles dans les logs.
- Suivre les erreurs 5xx, la latence des routes, les échecs de connexion, les webhooks et les réservations expirées.
- Créer des alertes limitées aux incidents qui exigent une action.

8 Sécurité et protection des données

Contrôle	Mise en œuvre attendue	Validation
Secrets	Variables d'environnement ou gestionnaire de secrets, jamais dans Git.	Recherche de secrets dans l'historique et rotation en cas d'exposition.
Cookies	HttpOnly Secure SameSite et durée limitée si la stratégie de session est retenue.	Inspection dans le navigateur et tests de déconnexion.
CSRF	Protection adaptée aux cookies de session et vérification des origines.	Requêtes intersites refusées.
CORS	Origines autorisées explicitement selon l'environnement.	Une origine inconnue ne reçoit pas d'autorisation.

Contrôle	Mise en œuvre attendue	Validation
Rate limiting	Clés par route identité et IP résolue depuis un proxy approuvé.	Les abus renvoient 429 sans bloquer un usage normal.
Entrées	Validation de taille format type et contenu des fichiers.	Les charges invalides sont refusées avant le domaine.
Dépendances	Mises à jour planifiées et analyse automatique.	Aucune vulnérabilité critique non acceptée.
Paielements	Prix calculés côté serveur et webhooks signés idempotents.	Modification du panier client sans effet sur le montant serveur.

Rate limiting et adresse IP

Le serveur ne doit faire confiance à X Forwarded For que lorsque la requête provient d'un reverse proxy configuré. En production, la chaîne de proxys de confiance doit être documentée. Les limites doivent couvrir au minimum le lien magique, les options et vérifications WebAuthn, le checkout, la recherche et l'inscription à l'infolettre.

9 Accessibilité et performance

Accessibilité

- Généraliser prefers reduced motion au curseur, aux lucioles, au tilt, à la waveform décorative et aux transitions.
- Désactiver complètement le curseur personnalisé sur tactile.
- Respecter WCAG AA pour les contrastes de texte, les contrôles et les états de focus.
- Fournir un nom accessible aux boutons d'icône et exposer correctement l'état lecture ou pause.
- Permettre l'utilisation complète au clavier avec un ordre de tabulation logique.
- Utiliser des titres HTML structurés, des zones landmarks et un lien d'évitement.
- Rendre la transcription navigable et indiquer la phrase active sans dépendre uniquement de la couleur.
- Afficher des messages d'erreur associés aux champs de formulaire.

Budgets de performance recommandés

Mesure	Cible de travail	Méthode
LCP mobile	Inférieur à 2,5 secondes au 75e percentile	Mesure réelle et Lighthouse en préproduction.
INP	Inférieur à 200 millisecondes au 75e percentile	Réduire le JavaScript et les tâches longues.
CLS	Inférieur à 0,1	Réserver les dimensions des médias et composants.
Animations	60 images par seconde sur matériel courant	Profiler le curseur la waveform et la 3D.
JavaScript initial	Budget défini par page après la référence de phase 0	Suivre la taille des bundles dans la CI.

10 Tests qualité et mise en production

Pyramide de tests

Niveau	Cible	Exemples
Unitaire	Règles isolées	Format du temps, sélection de transcription, transitions Drop, expiration de réservation.
Composant	États d'interface	Lecteur, formulaires, curseur, résultats de recherche, messages d'erreur.
Intégration	API base de données Redis et Stripe simulé	Lien magique, rôles, réservation, webhook idempotent.
Parcours	Scénarios visibles de bout en bout	Connexion, lecture persistante, recherche, achat, administration.
Manuel	Qualité perceptuelle	Clavier, lecteur d'écran, mobile, mouvement réduit, réseau lent.

Parcours critiques avant lancement

- Un visiteur découvre le projet, lance un extrait et poursuit sa navigation sans interruption.
- Un utilisateur demande un lien magique, se connecte, se déconnecte et ne peut pas réutiliser le lien.
- Un membre tente une route administrateur et reçoit un refus.
- Deux utilisateurs tentent d'acheter le dernier produit disponible.
- Stripe renvoie deux fois le même webhook sans créer de doublon.
- Un administrateur programme un drop et le compte à rebours atteint l'ouverture attendue.
- Le site reste utilisable au clavier, sur mobile et avec mouvement réduit.

Stratégie de déploiement

1. Fusionner une petite série de changements vérifiés.
2. Exécuter lint compilation tests frontend tests backend et migrations sur une base vide.
3. Déployer en préproduction avec données non sensibles.
4. Exécuter la recette fonctionnelle et les audits.
5. Créer une sauvegarde ou un point de restauration avant la production.
6. Déployer puis surveiller erreurs latence connexions webhooks et commandes.
7. Revenir à la version précédente si les critères de santé ne sont pas respectés.

11 Backlog priorisé

Priorité	Zone	Tâche	Échéance	Statut
P0	Auth	Implémenter le lien magique à usage unique	Phase 1	À faire
P0	Auth	Relier la session frontend et backend	Phase 1	À faire
P0	Auth	Corriger la lecture des rôles JWT	Phase 1	À faire
P0	Boutique	Créer Drop et supprimer le calcul glissant	Phase 2	À faire
P0	Boutique	Réserver le stock de manière transactionnelle	Phase 2	À faire
P0	Stripe	Rendre les webhooks idempotents	Phase 2	À faire
P1	Audio	Créer le moteur audio partagé	Phase 3	À faire
P1	Audio	Ajouter le mini lecteur persistant	Phase 3	À faire
P1	Audio	Synchroniser la transcription	Phase 3	À faire
P1	Design	Créer le curseur fleur de lys	Phase 4	À faire
P1	Design	Créer les lucioles et modes accessibles	Phase 4	À faire

Priorité	Zone	Tâche	Échéance	Statut
P1	Accueil	Réviser Hero et preuves	Phase 5	À faire
P1	Design	Formaliser tokens et familles d'animation	Phase 5	À faire
P1	Données	Supprimer les fallbacks locaux en production	Phase 6	À faire
P1	CSS	Découper globals.css	Phase 6	À faire
P2	Admin	Gérer épisodes invités et transcriptions	Phase 7	À faire
P2	Admin	Gérer drops produits et stock	Phase 7	À faire
P2	Qualité	Ajouter CI préproduction et observabilité	Phase 8	À faire
P2	SEO	Ajouter métadonnées et cartes de partage	Phase 8	À faire
P3	Produit	Évaluer flux RSS et statistiques d'écoute	Après V2	À évaluer

Définition des priorités P0 bloque la sécurité ou la vente. P1 définit l'expérience principale. P2 prépare l'exploitation et le lancement. P3 peut attendre après la version publique.

12 Organisation du travail

Cadence hebdomadaire réaliste

Moment	Action	Durée indicative
Début de semaine	Choisir une tâche principale et une tâche courte. Vérifier les dépendances.	Vingt minutes
Séance de développement	Travailler par petits changements testables et commiter un résultat cohérent.	Une à trois heures
Fin de séance	Lancer les tests concernés et noter le prochain point précis.	Dix minutes
Fin de semaine	Faire une démonstration, mettre à jour le backlog et mesurer l'avancement.	Trente minutes

Règle de taille des tâches

Une tâche devrait produire un changement vérifiable en une ou deux séances. Si elle contient plusieurs verbes importants, il faut probablement la découper. Par exemple, créer le lecteur persistant devient créer l'état global, brancher l'élément audio, afficher le mini lecteur, synchroniser la navigation et ajouter les tests.

Définition de terminé

- ☐ Le comportement demandé fonctionne dans le cas normal.
- ☐ Les états de chargement erreur vide et expiration sont traités lorsque pertinents.
- ☐ Le clavier le mobile et le mouvement réduit sont vérifiés.
- ☐ Les tests appropriés sont ajoutés et passent.
- ☐ La documentation et les variables d'environnement sont à jour.
- ☐ Aucun secret ni donnée réelle de production n'est présent dans le commit.
- ☐ La fonctionnalité est vérifiée en préproduction avant publication.

13 Critères de réussite

Objectif	Indicateur	Seuil de validation
----------	------------	---------------------

Objectif	Indicateur	Seuil de validation
Identité sécurisée	Tests de connexion rôles expiration et déconnexion	Tous les parcours critiques passent.
Audio distinctif	Lecture continue et interaction avec la transcription	Aucune interruption involontaire pendant la navigation.
Boutique fiable	Tests de concurrence et webhooks répétés	Aucune survente ni commande dupliquée dans les scénarios testés.
Interface accessible	Audit clavier contraste et mouvement réduit	Aucun blocage critique et conformité AA visée.
Performance	Core Web Vitals	LCP inférieur à 2,5 s, INP inférieur à 200 ms et CLS inférieur à 0,1 au 75e percentile lorsque les données réelles sont disponibles.
Maintenance	Temps pour localiser et modifier un composant	Styles données et responsabilités suivent une convention documentée.
Autonomie éditoriale	Publication sans modification du code	Épisodes et drops peuvent être administrés depuis le back office.

Décision de lancement

La version publique peut être lancée lorsque toutes les tâches P0 sont terminées, que les parcours critiques passent en préproduction et qu'une procédure de retour arrière existe. Les fonctions P2 encore incomplètes doivent être retirées de l'interface ou clairement désactivées plutôt que laissées dans un état ambigu.

14 Annexes techniques

Structure frontend suggérée

- src app routes layouts métadonnées et frontières serveur client
- src components ui composants génériques accessibles
- src features audio moteur waveform transcription et mini lecteur
- src features auth connexion session WebAuthn et protections d'interface
- src features episodes listes détails invités et recherche
- src features shop drops produits panier et checkout
- src lib api client erreurs contrats et clés de requête
- src styles tokens base animations audio et pages
- src test fixtures utilitaires et scénarios

Structure backend suggérée

- auth session lien magique WebAuthn JWT ou adaptateur de transition
- episode épisode invité transcription publication
- shop drop produit réservation commande paiement
- admin cas d'usage administratifs et audit
- common erreurs validation sécurité temps et identifiants
- infrastructure Redis Stripe courriel stockage et configuration
- db migration migrations Flyway ordonnées et testées

Variables de mouvement suggérées

Variable	Valeur initiale	Usage
motion fast	120 à 180 ms	Survols et retours visuels courts.
motion standard	220 à 320 ms	Ouverture de contrôles et transitions courantes.
motion organic	400 à 800 ms	Lucioles et braises.
ease standard	Courbe douce cohérente	Composants d'interface.
glow low	Faible opacité	État par défaut.
glow active	Intensité liée au son ou au focus	Lecture et interaction.

Checklist de première semaine

- ☐ Créer la branche V2.
- ☐ Mettre le README et les versions à jour.
- ☐ Écrire le scénario reproductible du lien magique actuel.
- ☐ Ajouter un test montrant que le rôle administrateur est perdu dans le filtre actuel.
- ☐ Écrire un test montrant que la date du drop glisse toujours de dix huit jours.
- ☐ Mesurer les pages principales et enregistrer les résultats.
- ☐ Créer les premières tâches des phases 1 et 2 dans le gestionnaire de projet.

Conclusion opérationnelle

Le projet possède déjà une base visuelle et technique différenciante. La prochaine version doit transformer cette richesse en un système cohérent. Les premières semaines doivent donc sécuriser l'identité et la boutique. Le travail créatif peut ensuite se concentrer sur le lecteur audio persistant, le curseur fleur de lys, les lucioles et un accueil plus crédible. Cette séquence protège la fiabilité du produit tout en conservant ce qui rend La Cabane du Lys reconnaissable.